Meeting 17th March

Tuesday, March 17, 2026 12:59 PM

Week 1

Thursday, March 19, 2026 11:40 AM

Day 1

Thursday, March 19, 2026 11:33 AM

1. My Role Purpose

Thursday, March 19, 2026 1:27 PM

As a **Security Architect**, my role is to ensure that security is designed into systems, applications, integrations, platforms, and delivery processes from the beginning, rather than added later as a reactive control.

I act as a **risk-informed design authority** who translates business needs, technical realities, regulatory obligations, and threat exposure into practical security requirements, architecture decisions, and assurance expectations.

My role is not only to identify security gaps, but also to help teams make secure and workable decisions that support the business or service mission.

2. What I Own

Thursday, March 19, 2026 1:27 PM

I own the following from a security architecture standpoint:

A. Security Requirements Definition

- Define security requirements based on business function, system criticality, threat exposure, and data sensitivity
- Ensure security is included as part of the design, not only during testing
- Identify mandatory security activities and control expectations

B. Security Architecture Review

- Review solution designs, trust boundaries, data flows, integrations, hosting models, and access patterns
- Identify architecture-level security risks and control gaps
- Recommend security design improvements and compensating controls

C. Security Assurance Input

- Define or influence required assurance activities such as:
    - threat modeling
    - secure coding expectations
    - SAST / SCA
    - VAPT
    - logging validation
    - access review
    - go-live criteria
    - residual risk treatment

D. Security Guidance and Standards

- Contribute to or define security standards, baselines, patterns, and SOPs
- Help teams interpret standards in practical project terms

E. Risk and Exception Advisory

- Assess whether risks are acceptable, need remediation, or require formal exception handling
- Support documentation of residual risks and compensating controls

3. What I Influence

Thursday, March 19, 2026 1:28 PM

I may not directly own delivery, operations, or procurement, but I influence:

- secure design decisions
- identity and access models
- cloud and infrastructure patterns
- logging and monitoring readiness
- testing expectations
- remediation prioritization
- vendor engagement quality
- residual risk decisions
- security control adoption in project teams

4. What I Review

Thursday, March 19, 2026 1:28 PM

I review:

- architecture and solution diagrams
- system and integration trust boundaries
- authentication and authorization designs
- data handling flows
- cloud service usage patterns
- privileged access designs
- vendor testing outcomes and reports
- open findings before commissioning or go-live
- requests for compensating controls or risk acceptance

5. What Success Looks Like

Thursday, March 19, 2026 1:28 PM

5. What Success Looks Like

Success for a Security Architect means:

- security is addressed early and consistently
- high-risk design issues are caught before implementation or go-live
- teams understand the security requirements and why they matter
- security advice is practical and implementable
- risks are clearly articulated and managed appropriately
- architecture decisions are defensible, proportionate, and auditable
- security is seen as enabling trusted delivery, not only as a gate

6. Industry-Specific Emphasis

Thursday, March 19, 2026 1:28 PM

Financial Institution (FI)

In FI environments, my role places stronger emphasis on:

- transaction integrity
- fraud resistance
- privileged access control
- payment and card/account data protection
- stronger segregation of duties
- stronger go-live assurance and testing rigor
- clear auditability of sensitive actions

Examples of high-focus data and workflows in FI:

- cardholder/payment-related data
- customer account details
- transaction histories
- approval or authorization workflows
- treasury or high-value internal financial operations

GovTech / Public Sector

In GovTech or public agency environments, my role places stronger emphasis on:

- protection of citizen and resident personal data
- privacy-by-design
- lawful and accountable access to records
- resilience and trust in public digital services
- public-facing service integrity
- inter-agency data handling considerations
- strong auditability and role separation

Examples of high-focus data and workflows in GovTech:

- citizen personal data
- permit or license information
- case and workflow records
- officer actions and approvals
- public service requests and decision trails

Generic Industry Example – Real Estate Firm

In a real estate environment, my role remains the same in principle, but the practical emphasis usually shifts toward:

- customer and tenant personal data protection
- confidentiality of contracts and supporting documents
- secure portals and document workflows
- SaaS and vendor risk management
- practical security controls that fit business agility and operational cost

Examples of high-focus data and workflows in Real Estate:

- customer or tenant profiles
- ID copies and financial/employment documents
- property transaction or rental application records
- broker/agent/admin access separation
- contract generation, storage, and sharing

7. Personal Reflection Notes

Thursday, March 19, 2026 1:30 PM

What parts of this role feel strongest for me today?
[Write here]

What parts of this role do I want to refresh most?
[Write here]

What areas have changed the most since I last actively performed them?
[Write here]

Day 2 (Architecture Principles)

Thursday, March 19, 2026 11:33 AM

The goal is to show that you, as a Security Architect, have a **repeatable decision-making lens**.

If you were writing this in your workbook, it could look like this:

My 10 Core Security Architecture Principles

1. Least Privilege
2. Defense in Depth
3. Secure by Design
4. Zero Trust / Never Implicitly Trust
5. Segmentation and Isolation
6. Strong Identity, Authentication, and Authorization
7. Data Protection Across Lifecycle
8. Secure Defaults and Hardening
9. Auditability and Accountability
10. Risk-Based and Proportionate Control Design

Then for each one, add:

- principle statement
- why it matters
- FI example
- GovTech example
- what I, as a Security Architect, would check

That becomes a very strong refresher document.

Purpose of this exercise

The purpose of this exercise is to define the principles I want to apply consistently across projects, regardless of industry or technology.

The principle stays the same.
The **emphasis changes by industry** depending on:

- data sensitivity
- business criticality
- regulatory expectations
- threat profile
- customer or citizen trust impact

1. Least Privilege

Thursday, March 19, 2026 11:35 AM

Principle Statement

Every user, application, service, administrator, and vendor should only have the minimum access necessary to perform their function.

Why it matters

Excessive access is one of the most common causes of:

- data exposure
- fraud
- internal misuse
- lateral movement after compromise
- poor accountability

FI emphasis

Very important for:

- support teams
- fraud teams
- operations users
- privileged administrators
- third-party support or vendor access

Example:
A support engineer should not have unrestricted access to production customer account or credit card-related data.

- GovTech emphasis
- Very important for:
- officers handling citizen records
- contractors
- privileged administrators
- teams working across agency boundaries
- **Example:**
  An officer should not be able to access all citizen records by default; access must align with their role and mandate.

Real Estate emphasis

Very important for:

- sales agents
- tenant operations teams
- finance teams
- outsourced IT or SaaS administrators

Example:
A property agent should not be able to access all tenant documents, payment histories, and internal

finance records.

What I would check as Security Architect

- role and permission model
- broad or shared access
- vendor access boundaries
- privileged access controls
- role review and approval process

2. Defense in Depth

Thursday, March 19, 2026 11:35 AM

Principle Statement

No single control should be relied upon as the only line of defense. Security should exist in multiple layers.

Why it matters

Any single control can fail:

- credentials can be stolen
- a WAF can be bypassed
- code can contain a flaw
- a patch can be missed
- a user can make an error

FI emphasis

Especially important because compromise can directly affect:

- funds
- transaction integrity
- regulated data
- fraud exposure
- customer trust

Example:
Online banking should rely on layered controls such as MFA, secure coding, API protection, WAF, fraud monitoring, and audit logging—not only on a login page.

GovTech emphasis

Especially important because compromise can affect:

- citizen trust
- confidentiality of personal data
- service continuity
- integrity of public records
- public accountability

Example:
A citizen service portal should include layered controls across identity, application logic, backend segmentation, logging, and restricted data access.

Real Estate emphasis

Still important, especially for:

- customer portals
- document handling
- SaaS integrations
- admin access

Example:

A tenant portal should not rely only on username and password; it should also include role-based access control, secure file handling, logging, and secure admin controls.

What I would check as Security Architect

- whether one failed control causes total compromise
- whether detective and monitoring controls exist
- whether sensitive data remains protected even if an application flaw exists
- whether multiple control layers are intentionally designed

3. Secure by Design

Thursday, March 19, 2026 11:36 AM

Principle Statement

Security requirements must be incorporated at design stage, not added later after implementation.

Why it matters

Late security usually results in:

- expensive rework
- rushed compensating controls
- weak design decisions
- delayed go-live
- poor user experience

FI emphasis

Important for:

- payment or transaction systems
- credit card or account-related flows
- customer onboarding or servicing workflows
- privileged internal operations

Example:
A card servicing portal should define access control, sensitive logging restrictions, authentication strength, and VAPT expectations before development starts.

GovTech emphasis

Important for:

- citizen-facing services
- permit or case workflows
- approval or decision systems
- systems handling personal data

Example:
A citizen application system should define identity, privacy, data retention, officer access, and logging requirements during design.

Real Estate emphasis

Important for:

- customer and tenant portals
- document management systems
- contract workflow systems
- SaaS-heavy business processes

Example:
A property management portal should define document access control, admin segregation, and secure vendor integration during design—not only before production.

What I would check as Security Architect

- whether security requirements were defined early
- whether architecture assumptions are documented
- whether trust boundaries and sensitive data flows were reviewed
- whether assurance activities were included in project planning

4. Zero Trust / Never Implicitly Trust

Thursday, March 19, 2026 11:36 AM

Principle Statement

No user, application, service, or network location should be automatically trusted simply because it is "internal."

Why it matters

Many real-world compromises come from:

- stolen internal credentials
- over-permissioned staff
- insider misuse
- weak trust assumptions
- compromised internal devices or applications

FI emphasis

Important for:

- internal finance operations
- treasury systems
- privileged admin consoles
- internal APIs and support tools

Example:
An internal reconciliation application should still enforce strong authentication, restricted authorization, and auditable access.

GovTech emphasis

Important for:

- internal officer systems
- administrative workflows
- cross-agency systems
- privileged platforms

Example:
An internal officer portal should not assume all staff users are equally trusted just because they are on a government network.

Real Estate emphasis

Important for:

- CRM platforms
- finance and payroll systems
- admin panels
- cloud consoles

Example:
Internal finance or tenant management systems should still enforce strong identity and access control rather than rely on network location.

What I would check as Security Architect

- assumptions about internal trust
- service-to-service authentication
- admin identity design
- trust boundaries in architecture diagrams
- whether internal access is actually governed

5. Segmentation and Isolation

Thursday, March 19, 2026 11:37 AM

Principle Statement

Applications, environments, data domains, administrative paths, and privileged functions should be separated to reduce blast radius.

Why it matters

Without segmentation:

- lateral movement becomes easier
- admin functions become overexposed
- production becomes reachable from lower-trust systems
- sensitive data domains mix unnecessarily

FI emphasis

Highly important for:

- internet-facing vs internal systems
- production vs non-production
- customer-facing channels vs admin tools
- payment or card data environments vs general environments

Example:
A customer-facing banking interface should not share the same trust zone as administrative management systems or sensitive back-end data stores.

GovTech emphasis

Important for:

- citizen-facing services vs internal case systems
- admin paths vs user-facing paths
- high-sensitivity records vs lower-sensitivity services
- cross-agency boundaries where needed

Example:
A public portal should be separated from internal officer workflow systems and from privileged admin management channels.

Real Estate emphasis

Important for:

- customer portal vs internal admin use
- document storage vs public web systems
- dev/test/prod separation
- privileged support access

Example:
A property listing or tenant portal should not have direct, open connectivity to document repositories or finance records.

What I would check as Security Architect

- network and trust segmentation
- production and non-production separation
- admin vs user access paths
- separation of sensitive stores
- lateral movement risks between components

6. Strong Identity, Authentication, and Authorization

Thursday, March 19, 2026 11:37 AM

Principle Statement

Identity is the foundation of access. The architecture must clearly define who is accessing what, how identity is validated, and what permissions are granted.

Why it matters

Weak identity or access design results in:

- broken access control
- privilege abuse
- session hijacking
- poor accountability
- insecure admin access

FI emphasis

Critical for:

- customer login
- high-risk actions
- staff admin access
- payment or card management workflows
- privileged approvals

Example:
High-risk banking actions should require stronger authentication or tighter authorization logic than low-risk informational actions.

GovTech emphasis

Critical for:

- citizen identity
- officer access
- admin functions
- cross-agency access controls
- decision workflows

Example:
Citizen systems should use strong and trusted digital identity mechanisms, while officer systems should enforce role-based access and stronger admin controls.

Real Estate emphasis

Important for:

- buyer/tenant portals
- sales agent access
- finance/admin access
- vendor or service provider access

Example:

An agent should have different permissions from finance, legal, and operations staff, and that separation should be enforced in the application.

What I would check as Security Architect

- identity provider and trust model
- admin MFA or stronger controls
- authorization enforcement design
- separation of duties
- session management and privilege escalation points

7. Protect Data Throughout Its Lifecycle

Thursday, March 19, 2026 11:37 AM

Principle Statement

Sensitive data must be protected during collection, processing, storage, transfer, sharing, archival, and disposal.

Why it matters

Data exposure often happens outside the main database through:

- logs
- exports
- reports
- email
- test environments
- support workflows
- backups

FI emphasis

Especially critical for:

- credit card or payment-related data
- customer account details
- transaction records
- KYC documents
- fraud-sensitive information

Example:
Sensitive card or payment-related data should be masked where appropriate, tightly controlled, encrypted, and not exposed through logs or support workflows.

GovTech emphasis

Especially critical for:

- personal data
- citizen records
- permit, case, or application data
- document uploads
- official decision records

Example:
Citizen data should be protected in storage, transit, logs, case workflows, and download/export processes.

Real Estate emphasis

Especially critical for:

- ID copies
- salary and employment proofs
- rental and property transaction documents

- customer or tenant data
- contract files

Example:
Uploaded supporting documents for property applications should not be broadly accessible internally or stored in uncontrolled locations.

What I would check as Security Architect

- data classification and sensitivity mapping
- encryption in transit and at rest
- data flow and sharing paths
- masking or tokenization needs
- logging and export exposure
- retention and deletion handling
- test data practices

8. Secure Defaults and Hardening

Thursday, March 19, 2026 11:38 AM

Principle Statement

Systems should start from a secure baseline by default, rather than depend on manual hardening after deployment.

Why it matters

Manual and late hardening is inconsistent and often missed under delivery pressure.

FI emphasis

Important for:

- cloud and hybrid platforms
- middleware
- privileged consoles
- deployment pipelines
- database platforms
- administrative endpoints

Example:
Default deployment patterns should restrict exposure, enforce logging, control secrets properly, and remove unnecessary services or permissive settings.

GovTech emphasis

Important because:

- multiple teams may build services with varying maturity
- consistency is essential for assurance
- centralized baselines are often expected

Example:
New applications should inherit secure baseline configurations for identity integration, logging, encryption settings, and hardened runtime or platform controls.

Real Estate emphasis

Important because:

- teams may be smaller
- SaaS usage may be heavy
- secure defaults reduce reliance on ad hoc security decisions

Example:
A CRM or portal system should start with strong admin access restrictions, secure storage settings, and logging enabled by default.

What I would check as Security Architect

- baseline standards
- hardened templates or deployment patterns
- default logging and monitoring settings
- secrets and key management defaults

- unnecessary public exposure
- whether project teams are weakening baseline settings

9. Auditability and Accountability

Thursday, March 19, 2026 11:38 AM

Principle Statement

Security-relevant actions must be attributable to a person, role, or service identity and supported by reliable logging.

Why it matters

Without auditability:

- incidents are harder to investigate
- fraud or misuse is harder to detect
- compliance and assurance are weakened
- accountability is reduced

FI emphasis

Critical for:

- transaction approvals
- customer record access
- privileged overrides
- operational changes
- fraud investigations

Example:
Access to sensitive customer data, card account changes, and privileged system actions should all be attributable and reviewable.

GovTech emphasis

Critical for:

- access to citizen records
- officer approvals and decisions
- administrative or privileged changes
- public service records and audit trails

Example:
Officer actions on citizen cases or records should be logged sufficiently for audit and investigation.

Real Estate emphasis

Important for:

- document downloads
- changes to customer or tenant records
- administrative updates
- vendor or agent actions on contracts or applications

Example:
Any access to sensitive tenancy or transaction documents should be auditable and attributable.

What I would check as Security Architect

- which events are logged

- whether logs are useful and reviewable
- whether logs contain sensitive data that should be masked
- whether privileged actions are captured
- retention and integrity of logs

10. Risk-Based Security and Proportionate Controls

Thursday, March 19, 2026 11:39 AM

Principle Statement

Security controls should match the business criticality, data sensitivity, threat exposure, and regulatory or contractual expectations of the system.

Why it matters

If controls are too weak:

- risk remains unmanaged

If controls are too heavy:

- delivery slows unnecessarily
- teams bypass process
- security loses credibility

FI emphasis

Control depth is often strongest for:

- digital banking
- payment systems
- card-related services
- customer account platforms
- privileged operational systems

GovTech emphasis

Control depth is often strongest for:

- citizen-facing identity or personal data systems
- major public service platforms
- approval-heavy or official decision systems
- systems supporting public trust or essential service continuity

Real Estate emphasis

Control depth is often strongest for:

- customer portal systems
- document submission and storage platforms
- finance-related systems
- broker/agent/admin workflows involving sensitive documents or data

What I would check as Security Architect

- asset and business criticality
- data sensitivity
- internet or external exposure
- impact of compromise
- threat model and likely abuse cases
- dependency on third parties
- proportion of controls to actual risk

Day 2 Reflections Notes

Thursday, March 19, 2026 1:57 PM

Which principles do I already use naturally?
[Write here]

Which principles do I want to apply more consciously?
[Write here]

Which industry context feels strongest for me today?
[Write here]

Which industry context do I want to refresh more deeply?
[Write here]

Day 3 (Stakeholder Map)

Thursday, March 19, 2026 11:41 AM

Draw a Stakeholder Map

Who needs what from security, what conflicts arise, and how the Security Architect supports each group

This is one of the most important exercises because a senior Security Architect succeeds not only by knowing controls, but by **working through people**.

Purpose of this exercise

A Security Architect does not succeed by technical knowledge alone.
Success depends on understanding:

- who the stakeholders are
- what each stakeholder needs from security
- where friction usually occurs
- how to support each group effectively

Stakeholder 1 – Business Owner / Product Owner / Service Owner

Thursday, March 19, 2026 1:24 PM

Stakeholder 1 – Business Owner / Product Owner / Service Owner

What they need from security

- clear and timely security requirements
- decisions that are practical and business-aware
- confidence that security will not delay the project unnecessarily
- clarity on go-live readiness and major risks

Typical conflicts

- security perceived as a blocker
- tension when findings delay launch
- frustration if security advice appears late
- pressure to accept open risks

How I support them

- engage early
- explain security in business terms
- distinguish critical issues from lower-priority items
- provide decision options, not just objections
- support realistic planning for remediation and assurance

FI emphasis

The business owner is usually most concerned about:

- transaction integrity
- fraud exposure
- financial loss
- customer trust
- service disruption

GovTech emphasis

The service owner is usually most concerned about:

- citizen trust
- public service continuity
- privacy
- public accountability
- confidence before launch

Real Estate emphasis

The business owner is usually most concerned about:

- client and tenant trust
- smooth onboarding and operations
- document confidentiality
- practical cost-effective security

Stakeholder 2 – Project Manager / Delivery Lead

Thursday, March 19, 2026 11:48 AM

Stakeholder 2 – Project Manager / Delivery Lead

What they need from security

- clear checkpoints
- predictable review processes
- known dependencies and timelines
- clarity on testing and sign-off expectations

Typical conflicts

- security activities introduced too late
- remediation affecting delivery timelines
- unclear entry/exit criteria for review
- uncertainty on whether go-live will be approved

How I support them

- define security checkpoints early
- provide clear templates and review criteria
- help plan threat modeling, VAPT, and remediation realistically
- communicate mandatory vs optional activities clearly

FI emphasis

Expect stronger sensitivity to:

- deeper assurance requirements
- testing cycles
- retesting and formal sign-off expectations

GovTech emphasis

Expect stronger sensitivity to:

- policy alignment
- privacy review
- public launch confidence
- cross-team or cross-agency dependencies

Real Estate emphasis

Expect stronger need for:

- practical, easy-to-follow security planning
- clarity around vendor and SaaS review dependencies

Stakeholder 3 – Solution Architect / Engineering Lead

Thursday, March 19, 2026 11:48 AM

Stakeholder 3 – Solution Architect / Engineering Lead

What they need from security

- practical architecture guidance
- approved patterns and reference points
- help translating policy into design decisions
- support with difficult trade-offs

Typical conflicts

- security requirements feel too generic
- unclear implementation expectations
- performance or usability concerns
- disagreement on architecture choices

How I support them

- provide practical patterns, not only policy statements
- review data flows and trust boundaries together
- explain rationale behind recommendations
- prioritize based on risk rather than abstract theory

FI emphasis

Likely focus areas:

- transaction paths
- maker/checker controls
- secure integrations
- privileged operational workflows
- sensitive audit trails

GovTech emphasis

Likely focus areas:

- citizen identity and privacy
- data minimization
- inter-agency access
- officer role separation
- public-facing service assurance

Real Estate emphasis

Likely focus areas:

- portal and CRM security
- document handling
- SaaS integration
- role separation across agents, operations, finance, and admin

Stakeholder 4 – Development Team / Application Team

Thursday, March 19, 2026 2:01 PM

Stakeholder 4 – Development Team / Application Team

What they need from security

- clear secure coding expectations
- practical remediation advice
- help understanding tool findings
- realistic controls that fit delivery workflows

Typical conflicts

- too many false positives
- unclear remediation guidance
- frustration with merge or release gates
- late design changes impacting implementation

How I support them

- provide developer-friendly standards
- prioritize true risk
- help tune or interpret tool outputs
- explain common weakness patterns clearly
- separate must-fix-now issues from backlog items

FI emphasis

Common areas of focus:

- broken access control
- transaction abuse
- secure handling of sensitive financial data
- fraud-resistant design
- strong audit logging

GovTech emphasis

Common areas of focus:

- secure handling of personal data
- officer/citizen access separation
- privacy-aware logging
- correct authorization logic
- secure workflows and approvals

Real Estate emphasis

Common areas of focus:

- secure document upload/download
- portal access control
- CRM access separation
- secure handling of user-submitted files and data

Stakeholder 5 – Infrastructure / Cloud / Platform Team

Thursday, March 19, 2026 2:02 PM

Stakeholder 5 – Infrastructure / Cloud / Platform Team

What they need from security

- clear baseline expectations
- guidance on IAM, hardening, logging, exposure, and secrets
- clarity on ownership of remediation and findings
- support in prioritizing issues

Typical conflicts

- shared responsibility confusion
- too many posture or VM findings
- disputes over urgency
- platform teams overloaded with remediation requests

How I support them

- define baseline requirements clearly
- separate critical exposures from general hygiene items
- help establish ownership and remediation logic
- support exception decisions where justified

FI emphasis

Likely focus areas:

- segregation of high-value systems
- privileged access protection
- logging integrity
- hardened production environments
- tighter control of admin access

GovTech emphasis

Likely focus areas:

- approved patterns and baselines
- secure public-facing hosting
- logging and monitoring for service trust
- stronger access control for agency and admin users

Real Estate emphasis

Likely focus areas:

- secure cloud or SaaS configuration
- admin account protection
- secure storage of documents
- backup and operational resilience

Stakeholder 6 – Security Operations / SOC / Vulnerability Management

Thursday, March 19, 2026 2:02 PM

Stakeholder 6 – Security Operations / SOC / Vulnerability Management

What they need from security

- observability built into design
- visibility into critical systems and attack paths
- useful logging
- clarity on who owns which findings

Typical conflicts

- poor logging design
- insufficient handover context
- no clear ownership of remediation
- too much noise without business or asset context

How I support them

- ensure logging requirements are defined early
- support architecture that enables monitoring
- align assurance outputs with operational visibility
- help map critical assets and their importance

FI emphasis

Likely focus areas:

- suspicious transactions
- privileged activity
- fraud indicators
- monitoring of high-value systems

GovTech emphasis

Likely focus areas:

- unauthorized access to citizen records
- misuse of officer privileges
- public portal abuse
- visibility into sensitive workflows

Real Estate emphasis

Likely focus areas:

- account compromise
- document exposure
- admin misuse
- portal abuse
- suspicious vendor activity

Stakeholder 7 – External Vendors / Pen-Testers / Service Providers

Thursday, March 19, 2026 2:03 PM

Stakeholder 7 – External Vendors / Pen-Testers / Service Providers

What they need from security

- clear scope
- rules of engagement
- technical context
- expectations for reporting and retesting
- known contacts and escalation paths

Typical conflicts

- shallow testing
- poor-quality reports
- false positives
- weak business context in findings
- unclear retest or closure expectations

How I support them

- provide clear scope and objectives
- explain key workflows and sensitive assets
- define expected report quality and evidence
- challenge weak findings or poor testing depth
- use structured rubrics to assess quality

FI emphasis

The vendor should understand:

- transaction-sensitive paths
- card or account exposure risks
- privileged flows
- deeper business impact of findings

GovTech emphasis

The vendor should understand:

- citizen-facing workflows
- privacy impact
- sensitive record access
- public trust considerations

Real Estate emphasis

The vendor should understand:

- customer portal and document workflows
- access to tenant or buyer data
- SaaS-heavy operational realities
- practical remediation constraints

Stakeholder 8 – Audit / Risk / Compliance / Privacy Teams

Thursday, March 19, 2026 2:03 PM

Stakeholder 8 – Audit / Risk / Compliance / Privacy Teams

What they need from security

- traceability
- evidence
- clear articulation of risks and decisions
- assurance that controls are not only written but implemented

Typical conflicts

- architecture decisions not documented clearly
- technical teams think a control is obvious but cannot evidence it
- policy and implementation do not align
- exceptions are poorly documented

How I support them

- document architecture decisions and assumptions clearly
- map requirements to controls and tests
- maintain evidence-oriented thinking
- ensure residual risks and compensating controls are clearly recorded

FI emphasis

Often stronger focus on:

- segregation of duties
- sensitive financial data protection
- accountability for high-value or privileged actions
- testing and control rigor

GovTech emphasis

Often stronger focus on:

- personal data protection
- lawful access
- accountability
- retention and handling of records
- policy and public-sector baseline alignment

Real Estate emphasis

Often stronger focus on:

- personal data handling
- document confidentiality
- vendor access control
- evidence that reasonable controls exist

Stakeholder 9 – Senior Management / Security Leadership

Thursday, March 19, 2026 2:03 PM

Stakeholder 9 – Senior Management / Security Leadership

What they need from security

- concise risk summaries
- decision-ready recommendations
- visibility of what is acceptable and what is not
- confidence that security is proportionate and under control

Typical conflicts

- pressure to move quickly
- preference for certainty when risk still exists
- frustration with technical detail without a decision path

How I support them

- communicate clearly and briefly
- frame risks in business terms
- identify decisions needed
- focus on the most material issues
- distinguish immediate blockers from manageable residual risks

FI emphasis

Senior management usually cares most about:

- fraud exposure
- financial loss
- service disruption
- reputation
- customer trust
- regulatory risk

GovTech emphasis

Senior management usually cares most about:

- citizen trust
- service reliability
- privacy failures
- public accountability
- reputational impact of incidents

Real Estate emphasis

Senior management usually cares most about:

- customer trust
- operational continuity
- document and personal data exposure
- practical cost-effective remediation

Day 3 Reflection Notes

Thursday, March 19, 2026 2:04 PM

Day 3 Reflection Notes

Which stakeholders am I strongest at working with?
[Write here]

Which stakeholder group do I want to communicate with more effectively?
[Write here]

Where do I see the most common friction in my past experience?
[Write here]

How can I position security more as an enabler?
[Write here]

Day 4 – Requirement-to-Control Exercise

Thursday, March 19, 2026 1:24 PM

Purpose of this exercise

The purpose of this exercise is to practice one of the core skills of a Security Architect:

Translate business context into security requirements, then into design controls, then into assurance or verification steps.

Use this sequence:

1. Understand the business function
2. Identify sensitive data and high-risk workflows
3. Determine threat exposure
4. Define security requirements
5. Translate requirements into architecture/design controls
6. Identify how controls will be verified
7. Consider residual risk

Exercise Template

Thursday, March 19, 2026 2:04 PM

Business context:
[Write here]

Data sensitivity:
[Write here]

Threat exposure:
[Write here]

Key users / roles:
[Write here]

Security requirement:
[Write here]

Design / architecture control:
[Write here]

How I verify it:
[Write here]

Residual risk consideration:
[Write here]

Industry-specific emphasis:
[Write here]

Scenario A – FI Example

Thursday, March 19, 2026 2:05 PM

Digital Credit Card / Payment Servicing Portal

Business context

A financial institution is launching a customer-facing portal where users can:

- view card-related account information
- access transaction information
- submit service requests
- upload supporting documents
- interact with back-end account or servicing functions

Data sensitivity

- card-related data
- transaction details
- customer identifiers
- uploaded supporting documents
- servicing and account-related records

Threat exposure

- internet-facing
- credential theft
- unauthorized data access
- broken access control
- API abuse
- session hijacking
- fraud-related misuse

Requirement 1

Thursday, March 19, 2026 2:04 PM

Requirement 1

Security requirement:
Users must only access their own card/account information and requests.

Design / architecture control:

- strong authentication
- secure session management
- strict server-side authorization
- object-level authorization in APIs
- no reliance on client-side controls

How I verify it:

- review authentication and authorization design
- test for IDOR and broken access control
- perform authenticated application and API testing
- review code or design logic for ownership checks

Residual risk consideration:
Any weakness in user-to-record authorization is a high-risk issue and should generally be treated as unacceptable for production.

Industry-specific emphasis:
In FI, this requirement directly protects customer financial data and trust.

Requirement 2

Thursday, March 19, 2026 2:04 PM

Requirement 2

Security requirement:
Sensitive customer or card-related data must not be exposed in logs, support workflows, downloads, or error messages.

Design / architecture control:

- logging standard with masking
- sanitized error handling
- restricted support access
- controlled exports
- encrypted data handling

How I verify it:

- review logging and support model
- test error messages and exposed diagnostics
- review export and reporting functions
- verify role-based access around support/admin activities

Residual risk consideration:
Exposure of sensitive data outside the intended business flow can have severe regulatory and reputational impact.

Industry-specific emphasis:
FI requires particularly careful handling of card/account-related information and transaction-associated data.

Requirement 3

Thursday, March 19, 2026 2:48 PM

Requirement 3

Security requirement:
High-risk actions must have stronger assurance and auditability.

Design / architecture control:

- stronger authentication for sensitive actions where needed
- clear audit logs for high-risk operations
- stronger validation around transaction-sensitive workflows

How I verify it:

- review high-risk workflow logic
- validate audit log coverage
- include business-abuse scenarios in testing

Residual risk consideration:
If high-risk actions cannot be strongly attributed and monitored, fraud and misuse risk increases significantly.

Industry-specific emphasis:
This is especially relevant where customer or staff actions could affect accounts, servicing outcomes, or transaction-related workflows.

Scenario B – GovTech Example

Thursday, March 19, 2026 2:48 PM

Scenario B – GovTech Example

Citizen Services Portal

Business context

A public agency is launching a citizen-facing portal where users can:

- submit service requests
- upload supporting documents
- view application or request status
- interact with back-office workflows and case processing

Data sensitivity

- citizen personal data
- application records
- uploaded documents
- internal case notes
- official service decisions or approval history

Threat exposure

- internet-facing
- unauthorized access to records
- privacy breaches
- misuse of officer or admin roles
- document exposure
- service disruption

Requirement 1

Thursday, March 19, 2026 2:48 PM

Requirement 1

Security requirement:
Citizens must only access their own records, documents, and application status.

Design / architecture control:

- strong authenticated sessions
- strict object-level authorization
- ownership and record-access checks
- separation between citizen-facing and officer-facing workflows
- secure API access control

How I verify it:

- review role and access model
- perform authenticated testing for horizontal privilege escalation
- validate object-level authorization across APIs and workflow actions

Residual risk consideration:
Unauthorized access to another citizen's records is a severe privacy and trust issue and should be treated as high severity.

Industry-specific emphasis:
In GovTech, this protects citizen trust, privacy, and confidence in public digital services.

Requirement 2

Thursday, March 19, 2026 2:48 PM

Requirement 2

Security requirement:
Citizen personal data must be protected throughout storage, transfer, logging, and officer access workflows.

Design / architecture control:

- encryption in transit and at rest
- masked or sanitized logs
- restricted officer access
- controlled export and download functions
- clear handling rules for uploaded documents

How I verify it:

- review data flow design
- review log design
- assess document handling and retention approach
- review officer access segregation

Residual risk consideration:
Weak data handling controls may result in privacy breaches or improper internal exposure.

Industry-specific emphasis:
GovTech places strong emphasis on protecting personal data and maintaining lawful, auditable access.

Requirement 3

Thursday, March 19, 2026 2:48 PM

Requirement 3

Security requirement:
Officer and administrative actions must be attributable, controlled, and reviewable.

Design / architecture control:

- role-based access control
- privileged action logging
- protected audit trails
- admin and officer role separation
- stronger controls for privileged functions

How I verify it:

- review role model and privileged pathways
- validate logging requirements and retention
- inspect whether elevated actions are attributable and reviewable

Residual risk consideration:
Weak accountability for officer or admin actions increases misuse risk and weakens public trust and audit defensibility.

Industry-specific emphasis:
In GovTech, accountability and lawful access are especially important.

Scenario C – Real Estate Example

Thursday, March 19, 2026 2:49 PM

Scenario C – Real Estate Example

Tenant / Buyer Portal

Business context

A real estate firm is launching a customer-facing portal where users can:

- submit rental or purchase applications
- upload personal and employment-related documents
- track status
- interact with agents and internal staff

Data sensitivity

- personal data
- ID copies
- employment and salary documents
- application records
- contract-related information

Threat exposure

- internet-facing
- insecure document access
- excessive internal access
- vendor or SaaS misconfiguration
- account compromise
- data leakage through support workflows

Requirement 1

Thursday, March 19, 2026 2:49 PM

Requirement 1

Security requirement:
Customers must only access their own profile, documents, and application records.

Design / architecture control:

- authenticated portal access
- strong object-level authorization
- separate roles for customers, agents, admins, and operations
- secure document delivery controls

How I verify it:

- test for record access manipulation
- review role separation
- inspect document access mechanisms

Residual risk consideration:
Cross-customer document or record exposure is a serious trust and privacy issue.

Industry-specific emphasis:
In real estate, this protects tenant or buyer data and prevents document exposure across customers.

Requirement 2

Thursday, March 19, 2026 2:49 PM

Requirement 2

Security requirement:
Uploaded personal and financial documents must not be broadly accessible internally.

Design / architecture control:

- role-based internal access
- secure storage
- restricted download permissions
- logging for document access
- no uncontrolled sharing channels

How I verify it:

- review storage and role model
- validate access restrictions
- inspect whether downloads and exports are logged

Residual risk consideration:
Broad access to customer documents increases privacy, insider, and reputational risks.

Industry-specific emphasis:
This is especially relevant where firms collect ID, income, or tenancy verification documents.

Requirement 3

Thursday, March 19, 2026 2:50 PM

Requirement 3

Security requirement:
Admin and vendor access must be tightly controlled and auditable.

Design / architecture control:

- separate privileged accounts
- stronger authentication
- approved vendor access paths
- role-based admin actions
- clear audit logs

How I verify it:

- review admin and support model
- review access approval processes
- inspect audit logging for privileged actions

Residual risk consideration:
Weak vendor or admin governance increases exposure through the support path.

Industry-specific emphasis:
This matters especially where external platform providers or small IT teams manage core business systems.

Day 4 Reflection Notes

Thursday, March 19, 2026 2:51 PM

Day 4 Reflection Notes

Am I comfortable translating business context into security requirements?
[Write here]

Which step is hardest for me: requirements, control design, or verification?
[Write here]

Do I naturally think in terms of verification and evidence?
[Write here]

Which industry scenario felt easiest for me to reason through?
[Write here]

Day 5 – Architecture Review Flow

Thursday, March 19, 2026 1:24 PM

Purpose of this exercise

The purpose of this exercise is to practice how a Security Architect would run a practical architecture review from start to finish.

This is not just a checklist exercise.
It is a **structured decision-making process**.

Step 1 – Intake and Context Gathering

Thursday, March 19, 2026 2:51 PM

Step 1 – Intake and Context Gathering

Objective

Understand:

- what the system does
- who uses it
- what data it handles
- where it is hosted
- what it integrates with
- whether it is internet-facing
- what the business criticality is

What I ask for

- system overview
- architecture diagram
- data flow diagram
- user roles and access model
- hosting and deployment model
- list of integrations
- data classification
- known constraints or deadlines
- expected go-live timeline

Industry-specific review emphasis

FI:
Pay special attention to:

- transaction-sensitive functions
- credit card, payment, or account-related data
- customer-impacting integrations
- approval or override workflows
- privileged operational functions

GovTech:
Pay special attention to:

- citizen personal data
- public-facing exposure
- officer and admin workflows
- inter-agency access or sharing
- record handling and accountability needs

Real Estate:
Pay special attention to:

- customer/tenant document handling
- SaaS and vendor integrations

- portal and CRM exposure
- broker/agent/admin role separation
- document access and storage model

Step 2 – Identify Trust Boundaries and High-Risk Components

Thursday, March 19, 2026 2:51 PM

Step 2 – Identify Trust Boundaries and High-Risk Components

Objective

Identify where trust changes or where exposure becomes significant.

Typical trust boundaries

- internet user to application
- application to API
- API to data store
- user function to admin function
- vendor access to support path
- application to third-party service
- production to non-production

What I look for

- internet-facing endpoints
- privileged interfaces
- file upload/download paths
- sensitive data stores
- external dependencies
- weakly protected internal services
- places where broad trust is assumed

Industry-specific review emphasis

FI:
Pay special attention to:

- transaction paths
- customer-to-core integrations
- payment/account data flows
- privileged support and back-office pathways

GovTech:
Pay special attention to:

- citizen record access boundaries
- public-to-back-office transitions
- officer/admin separation
- data sharing between systems or agencies

Real Estate:
Pay special attention to:

- customer portal to document storage flows
- vendor-managed system trust boundaries
- finance/admin and agent separation
- SaaS integration exposure

Step 3 – Derive Security Requirements

Thursday, March 19, 2026 2:51 PM

Step 3 – Derive Security Requirements

Objective

Translate the system and business context into mandatory security requirements.

Typical categories

- authentication
- authorization
- segmentation
- encryption
- logging and monitoring
- secrets management
- data handling and privacy
- admin and privileged access
- security testing requirements
- go-live control expectations

Industry-specific review emphasis

FI:
Requirements often become stronger around:

- transaction integrity
- sensitive financial data handling
- fraud-related workflows
- stronger assurance and testing depth
- evidential logging

GovTech:
Requirements often become stronger around:

- citizen personal data protection
- lawful access
- officer role separation
- accountability
- privacy-preserving logging
- service trust

Real Estate:
Requirements often become stronger around:

- secure portal access
- customer/tenant document handling
- vendor access control
- practical but effective logging and role separation

Step 4 – Review Design Controls

Thursday, March 19, 2026 2:53 PM

Step 4 – Review Design Controls

Objective

Assess whether the proposed design actually addresses the requirements.

What I review

- identity and authentication flow
- authorization model
- trust boundaries
- sensitive data handling
- encryption and key management
- secrets handling
- network and environment segregation
- admin access and support access
- logging and operational visibility
- dependency and integration trust model

Example questions I ask

- Where is the sensitive data?
- Who can access it?
- How is access validated?
- Can one user access another user's data?
- Are admin and user functions clearly separated?
- What is logged?
- Are logs useful without leaking sensitive data?
- How are external vendors or support users controlled?
- What happens if one layer of security fails?

Step 5 – Determine Assurance Activities

Thursday, March 19, 2026 2:53 PM

Step 5 – Determine Assurance Activities

Objective

Define what should be verified before go-live.

Typical assurance activities

- architecture review completion
- threat modeling
- secure coding expectations
- SAST / SCA
- application or API testing
- VAPT
- role and access review
- logging validation
- issue remediation review
- residual risk documentation

Industry-specific review emphasis

FI:
Often stronger emphasis on:

- deeper authenticated testing
- transaction and abuse-case validation
- stronger validation of privileged or sensitive paths
- formal retesting of critical findings

GovTech:
Often stronger emphasis on:

- citizen data access validation
- officer/admin access review
- privacy-related logging and data handling review
- confidence for public launch

Real Estate:
Often stronger emphasis on:

- portal and document access testing
- SaaS and admin access governance
- practical testing scaled to the risk of the business system

Step 6 – Identify Gaps and Recommend Actions

Thursday, March 19, 2026 2:55 PM

Step 6 – Identify Gaps and Recommend Actions

Objective

Summarize:

- what is acceptable
- what must change
- what should improve
- what may be accepted temporarily with compensating controls

Example output structure

- critical gaps
- high-priority issues
- recommended control improvements
- required assurance activities
- required actions before production
- items that may require risk acceptance

Example recommendations

- strengthen object-level authorization
- separate admin and user pathways
- restrict broad internal document access
- mask sensitive data in logs
- improve vendor support controls
- add stronger controls for privileged actions
- review retention and export mechanisms

Step 7 – Document Outcome and Closure Path

Thursday, March 19, 2026 2:55 PM

Step 7 – Document Outcome and Closure Path

Objective

Create an auditable record of:

- what was reviewed
- what risks were found
- what actions are required
- what can and cannot go live
- what residual risks remain

Example closure record structure

System / Project Name:
[Write here]

Review Date:
[Write here]

Participants:
[Write here]

Business Criticality:
[Write here]

Sensitive Data Involved:
[Write here]

Key Risks Identified:
[Write here]

Required Actions:
[Write here]

Assurance Activities Required Before Go-Live:
[Write here]

Open Issues:
[Write here]

Residual Risks:
[Write here]

Recommendation:
[Write here]

Approvals Needed:
[Write here]

Example End-to-End Summary Statement

Thursday, March 19, 2026 2:56 PM

Example End-to-End Summary Statement

As a Security Architect, my architecture review flow begins with understanding the business context, sensitive data, user roles, integrations, hosting model, and threat exposure. I then identify trust boundaries and high-risk components, derive the required security controls, assess the proposed design, define the assurance activities needed before go-live, and document required actions and any residual risks.

In FI, I typically apply greater emphasis to transaction integrity, payment or card/account data protection, stronger privileged access controls, fraud-sensitive workflows, and deeper pre-production assurance.

In GovTech, I typically apply greater emphasis to citizen personal data protection, privacy-aware design, officer/admin role separation, public service trust, lawful access, and stronger accountability of actions.

In a real estate environment, I typically apply greater emphasis to customer and tenant data protection, secure document handling, portal and SaaS security, role separation across agent/admin/finance functions, and practical controls that fit operational realities.

Day 5 Reflection Notes

Thursday, March 19, 2026 2:56 PM

Day 5 Reflection Notes

Do I have a clear, repeatable architecture review process?
[Write here]

Which part of the review process do I perform most confidently?
[Write here]

Which part do I want to improve—intake, requirements, gap analysis, or closure?
[Write here]

Can I adapt my review depth depending on industry and risk?
[Write here]

End of Week 1 – Consolidation Notes

Thursday, March 19, 2026 1:24 PM

End of Week 1 – Consolidation Notes

What I refreshed this week

[Write here]

What still feels rusty

[Write here]

Which artifacts from this week can I reuse in real work

[Write here]

Which industry context feels strongest for me

[Write here]

Which industry context I want to deepen next

[Write here]

My top 5 focus areas for Week 2

1. [Write here]
2. [Write here]
3. [Write here]
4. [Write here]
5. [Write here]

Week 2 Security Architect Refresher Workbook

Thursday, March 19, 2026 11:40 AM

Security Architect Refresher Workbook

Week 2 – Governance, Standards, SOPs, Exceptions, Assurance Gates, and Traceability

Purpose of Week 2

This week is designed to refresh my ability to:

- translate security expectations into **usable governance**
- distinguish between **policy, standard, guideline, procedure, and SOP**
- write security requirements that are **clear, enforceable, and auditable**
- support teams with **practical operational guidance**
- define and manage **security exceptions / risk acceptance**
- design **assurance gates** before go-live
- think in terms of **evidence and traceability**

Week 2 Objectives

By the end of Week 2, I should be able to:

- explain the difference between policy, standard, SOP, guideline, and playbook
- draft a security standard structure that project teams can use
- outline operational SOPs for common security activities
- define a practical exception / risk acceptance process
- create assurance gates for solution delivery and go-live
- map requirements to controls, tests, and evidence
- adapt the same governance concepts to FI, GovTech, and general industry contexts

Day 8

Monday, March 23, 2026 11:10 AM

Day 8 – Policy vs Standard vs SOP vs Guideline

Purpose of this exercise

The purpose of this exercise is to refresh the difference between governance document types so that I can:

- write the right document for the right need
- avoid mixing mandatory controls with optional guidance
- help teams understand what is required vs recommended
- improve auditability and consistency

1. Policy

Monday, March 23, 2026 11:10 AM

Definition

A **policy** states the organization's intent, principles, and high-level expectations.

Purpose

It answers:

- what must be achieved
- why it matters
- who is accountable

Characteristics

- high-level
- mandatory
- organization-wide or domain-wide
- approved by leadership or governance authority
- stable and less frequently changed

Example

"All internet-facing applications must undergo security assessment before production deployment."

Security Architect's role

- interpret policy into practical control expectations
- ensure architecture and project delivery align with policy intent
- identify where policy requires supporting standards or SOPs

2. Standard

Monday, March 23, 2026 11:11 AM

Definition

A **standard** defines the mandatory control requirements that must be followed to comply with policy.

Purpose

It answers:

- what specific controls or minimum requirements must be implemented
- what baseline applies
- what is required for compliance or assurance

Characteristics

- specific and measurable
- mandatory
- can be tested or audited
- usually aligned to technology, control domain, or process area

Example

"All privileged accounts must use MFA and must not use shared credentials."

Security Architect's role

- define or contribute to minimum mandatory controls
- ensure standards are practical and risk-based
- help project teams interpret standards in design terms

3. Procedure

Monday, March 23, 2026 11:11 AM

Definition

A **procedure** describes the steps required to carry out a process correctly.

Purpose

It answers:

- how a process is performed
- in what sequence
- by whom

Characteristics

- operational and process-oriented
- usually more detailed than a policy or standard
- may support one team or multiple teams

Example

Steps for requesting, approving, and reviewing privileged access.

Security Architect's role

- ensure procedures align with architecture and security control intent
- review whether procedures are sufficient to support consistent execution

4. SOP (Standard Operating Procedure)

Monday, March 23, 2026 11:11 AM

Definition

An **SOP** is a structured operational instruction set used by teams to perform recurring activities consistently.

Purpose

It answers:

- how teams should carry out recurring operational tasks
- what information is needed
- what checks must be completed
- what outputs or approvals are required

Characteristics

- practical and repeatable
- operational
- used by delivery, security, operations, or vendor teams
- often includes forms, checklists, and required outputs

Example

SOP for engaging an external penetration testing vendor.

Security Architect's role

- define or review SOPs where architecture, security assurance, or risk handling is involved
- make sure SOPs are usable by real project teams, not just written for compliance

5. Guideline

Monday, March 23, 2026 11:12 AM

Definition

A **guideline** provides recommended practices and implementation advice.

Purpose

It answers:

- what is recommended
- how teams may implement something well
- what good practice looks like

Characteristics

- recommended, not always mandatory
- practical and supportive
- useful where flexibility is needed

Example

Recommended secure coding practices for Node.js or Java.

Security Architect’s role

- provide practical implementation guidance
- bridge the gap between standards and real-world delivery

6. Playbook

Monday, March 23, 2026 11:12 AM

Definition

A **playbook** provides scenario-based instructions or response actions for specific situations.

Purpose

It answers:

- what to do in a defined scenario
- how to respond or coordinate
- what actions are expected under a known situation

Example

Playbook for handling a critical production vulnerability before go-live.

Security Architect's role

- contribute security decision points and architectural considerations
- ensure playbooks align with system realities and risk priorities

Industry-Specific Notes

Monday, March 23, 2026 11:12 AM

FI

Governance documents are usually expected to be:

- more formal
- more tightly controlled
- more evidence-driven
- stronger around segregation of duties, privileged access, data protection, and testing rigor

GovTech

Governance documents often require:

- alignment with public-sector security and privacy expectations
- strong accountability
- clear auditable wording
- consistency across agencies or teams
- attention to lawful data use and service trust

Real Estate

Governance documents usually need to be:

- practical
- easy to understand
- operationally lightweight but still enforceable
- especially useful for SaaS, document handling, and role access control

Day 8 Reflection Notes

Monday, March 23, 2026 11:13 AM

Where have I previously mixed up policy, standard, and SOP?
[Write here]

Do I naturally write enforceable language, or do I stay too high-level?
[Write here]

Which document type am I most comfortable creating?
[Write here]

Which document type do I want to improve most?
[Write here]

Day 9 – Writing Good Security Standards

Monday, March 23, 2026 11:13 AM

Purpose of this exercise

The purpose of this exercise is to refresh how to write standards that are:

- mandatory
- clear
- implementable
- measurable
- auditable

A good security standard should help teams know:

- what is required
- where it applies
- how it will be checked
- what happens if they cannot comply

1. Structure of a Good Security Standard

Monday, March 23, 2026 11:13 AM

Use the following template when drafting a standard.

Standard Title

[Write here]

Purpose

Describe why this standard exists.

Scope

State where the standard applies:

- all applications
- internet-facing systems
- privileged access
- cloud platforms
- vendors
- specific data types

Applicability

State which teams, systems, or environments are covered.

Mandatory Requirements

List the specific control requirements in clear language.

Use wording such as:

- must
- shall
- must not
- required

Avoid weak wording such as:

- should consider
- may want to
- where possible

Roles and Responsibilities

State who is responsible for:

- implementation
- review
- approval
- exception handling
- evidence retention

Verification / Evidence

State how compliance will be checked.

Examples:

- architecture review
- design approval
- access review
- VAPT report
- SAST output
- screenshots / system configuration evidence
- audit logs
- test results

Exceptions

State how non-compliance is handled and when an exception is required.

Review Frequency

State how often the standard should be reviewed.

2. Example Standard Areas a Security Architect Might Write

Monday, March 23, 2026 11:13 AM

- secure authentication standard
- privileged access standard
- encryption standard
- security logging standard
- internet-facing application assurance standard
- secure coding standard
- cloud baseline security standard
- vendor security testing standard
- API security standard

3. Example Standard Snippet

Monday, March 23, 2026 11:14 AM

Standard Title

Privileged Access Security Standard

Purpose

To ensure privileged access is controlled, attributable, and protected against misuse.

Scope

Applies to all production systems, cloud platforms, administrative consoles, and privileged operational functions.

Mandatory Requirements

- Shared privileged accounts must not be used unless formally approved and justified.
- Privileged users must use MFA.
- Privileged access must be role-based and approved.
- Privileged activity must be logged and reviewable.
- Vendors must not receive persistent privileged access without explicit approval.

Verification / Evidence

- access control review
- admin account inventory
- MFA evidence
- privileged access logs
- approval records

4. Security Architect Checklist for Good Standards

Monday, March 23, 2026 11:14 AM

When reviewing a standard, ask:

- Is the scope clear?
- Is the language mandatory and unambiguous?
- Can project teams understand what to do?
- Can an auditor verify compliance?
- Is there a defined owner?
- Is there an exception path?
- Does the standard match the actual risk level?

Industry-Specific Notes

Monday, March 23, 2026 11:15 AM

FI

Standards often need to be stronger around:

- credit card / account / payment-related data
- transaction integrity
- maker-checker and segregation of duties
- privileged operations
- stronger logging and assurance evidence

GovTech

Standards often need to be stronger around:

- personal data protection
- citizen-facing service security
- accountability of officer and admin actions
- retention and record handling
- privacy-preserving logging
- policy consistency across teams

Real Estate

Standards often need to be stronger around:

- document handling
- SaaS and vendor access
- internal role separation
- tenant or customer personal data protection
- practical secure portal controls

Day 9 Workbook Exercise

Monday, March 23, 2026 11:15 AM

Draft a standard skeleton for one of the following:

- privileged access
- security logging
- internet-facing application assurance
- cloud baseline security
- secure coding

Use this format:

Standard Title

[Write here]

Purpose

[Write here]

Scope

[Write here]

Applicability

[Write here]

Mandatory Requirements

1. [Write here]
2. [Write here]
3. [Write here]

Roles and Responsibilities

[Write here]

Verification / Evidence

[Write here]

Exceptions

[Write here]

Review Frequency

[Write here]

Day 9 Reflection Notes

Monday, March 23, 2026 11:15 AM

Am I able to write standards that are measurable?
[Write here]

Do my standards usually lean too technical or too generic?
[Write here]

Which standard area would I feel most confident writing today?
[Write here]

Which one do I want to practice more?
[Write here]

Day 10 – SOP Design

Monday, March 23, 2026 11:16 AM

Purpose of this exercise

The purpose of this exercise is to refresh how to design SOPs that teams can actually follow.

A good SOP should make recurring work:

- consistent
- understandable
- auditable
- repeatable

It should reduce confusion and improve execution quality.

1. What a Good SOP Should Include

Monday, March 23, 2026 11:16 AM

SOP Title

[Write here]

Purpose

What recurring activity does this SOP support?

Scope

What teams, systems, or situations does this SOP apply to?

Trigger / When to Use

When should the SOP be used?

Inputs Required

What information must be available before starting?

Roles Involved

Who performs, reviews, approves, or supports the activity?

Step-by-Step Process

Describe the steps in order.

Required Checks

What validations or approvals are required?

Outputs

What deliverables, records, or outcomes should exist?

Evidence / Records

What evidence should be retained?

Escalation Path

What happens if the SOP cannot be followed or a major issue occurs?

2. Example SOPs a Security Architect Might Need

Monday, March 23, 2026 11:16 AM

- SOP for engaging an external VAPT vendor
- SOP for internal architecture review
- SOP for security sign-off before go-live
- SOP for handling security exceptions
- SOP for reviewing critical findings before production
- SOP for validating remediation evidence
- SOP for onboarding a new internet-facing application

3. Example SOP – Engaging an External Security Testing Vendor

Monday, March 23, 2026 11:17 AM

Purpose

To ensure external security testing engagements are scoped, executed, and reviewed consistently.

Scope

Applies to all externally commissioned VAPT or specialized security testing engagements.

Trigger / When to Use

Use when a project requires security testing by an approved external vendor.

Inputs Required

- system description
- architecture diagram
- environment details
- scope boundaries
- contacts and escalation points
- test schedule
- sensitivity of data involved

Roles Involved

- project manager
- system owner
- security architect
- testing vendor
- platform or ops contact
- risk owner where needed

Steps

1. Confirm testing need and scope.
2. Define rules of engagement.
3. Identify environment and support contacts.
4. Confirm data sensitivity and handling restrictions.
5. Schedule testing window.
6. Review access and prerequisites.
7. Validate deliverable expectations.
8. Review draft findings.
9. Track remediation.
10. Validate retest and closure.

Outputs

- approved scope
- rules of engagement
- final report
- remediation tracker
- retest evidence
- sign-off record

Evidence / Records

- approval email or record
- vendor report
- remediation evidence
- retest outcome
- residual risk decision if needed

Industry-Specific Notes

Monday, March 23, 2026 11:17 AM

FI

SOPs may need stronger steps around:

- approval chains
- production testing restrictions
- sensitive transaction paths
- stronger retest requirements
- formal issue closure evidence

GovTech

SOPs may need stronger steps around:

- personal data handling
- officer/admin role checks
- privacy and accountability evidence
- stronger coordination with central security or governance

Real Estate

SOPs may need to be especially clear around:

- vendor coordination
- SaaS and platform dependencies
- document handling
- simpler but disciplined execution paths for smaller teams

Day 10 Workbook Exercise

Monday, March 23, 2026 11:17 AM

Draft an SOP for one of the following:

- internal security architecture review
- VAPT engagement
- security sign-off before go-live
- risk exception handling
- remediation closure validation

Use this structure:

SOP Title

[Write here]

Purpose

[Write here]

Scope

[Write here]

Trigger / When to Use

[Write here]

Inputs Required

[Write here]

Roles Involved

[Write here]

Step-by-Step Process

1. [Write here]
2. [Write here]
3. [Write here]

Required Checks

[Write here]

Outputs

[Write here]

Evidence / Records

[Write here]

Escalation Path

[Write here]

Day 10 Reflection Notes

Monday, March 23, 2026 11:18 AM

Can I design SOPs that teams would actually use?
[Write here]

Do I tend to write SOPs too high-level or too detailed?
[Write here]

Which SOP would be most valuable for my work today?
[Write here]

Day 11 – Security Exceptions and Risk Acceptance

Monday, March 23, 2026 11:18 AM

Purpose of this exercise

The purpose of this exercise is to refresh how to handle situations where a required control cannot be met immediately.

A mature security program does not pretend every gap can be fixed instantly.
Instead, it uses a controlled process for:

- identifying the gap
- understanding the risk
- applying compensating controls where possible
- obtaining accountable approval
- tracking expiry and review

1. When an Exception May Be Needed

Monday, March 23, 2026 11:18 AM

Examples include:

- legacy system cannot support MFA immediately
- vendor solution does not support a required control
- remediation cannot be completed before go-live
- operational dependency prevents immediate fix
- technology limitation exists but compensating controls are possible

2. What an Exception Must Include

Monday, March 23, 2026 11:18 AM

Exception Title

[Write here]

System / Project

[Write here]

Requirement Being Excepted

[Write here]

Reason for Exception

[Write here]

Risk Introduced

[Write here]

Compensating Controls

[Write here]

Residual Risk Level

[Write here]

Risk Owner

[Write here]

Approver(s)

[Write here]

Expiry Date

[Write here]

Review Date

[Write here]

Closure Criteria

[Write here]

3. Security Architect’s Role in Exception Handling

Monday, March 23, 2026 11:19 AM

My role is to assess:

- whether the exception is legitimate
- whether the risk is clearly articulated
- whether compensating controls are meaningful
- whether the exception is time-bound
- whether the system should still go live
- whether the exception is properly documented and approved

I should not let exceptions become:

- hidden non-compliance
- permanent shortcuts
- vague promises to fix later
- undocumented decisions

4. Good Exception Handling Questions

Monday, March 23, 2026 11:19 AM

Ask:

- What exact requirement is not being met?
- Why can it not be met now?
- Is the reason technical, operational, or commercial?
- What risk is introduced by not meeting it?
- What controls reduce the risk in the meantime?
- Who is accepting the risk?
- When will this be revisited?
- What evidence shows the compensating controls exist?

Industry-Specific Notes

Monday, March 23, 2026 11:19 AM

FI

Exceptions often require stronger scrutiny when they affect:

- transaction integrity
- card or payment-related data
- privileged access
- customer account protection
- fraud-sensitive workflows

GovTech

Exceptions often require stronger scrutiny when they affect:

- personal data protection
- citizen-facing services
- lawful access
- officer/admin accountability
- public trust or service continuity

Real Estate

Exceptions often require stronger scrutiny when they affect:

- customer or tenant document access
- internal role separation
- admin or vendor access
- portal exposure
- uncontrolled SaaS risks

Day 11 Workbook Exercise

Monday, March 23, 2026 11:20 AM

Draft a security exception using this format:

Exception Title

[Write here]

System / Project

[Write here]

Requirement Being Excepted

[Write here]

Business or Technical Reason

[Write here]

Risk Introduced

[Write here]

Compensating Controls

[Write here]

Residual Risk Level

[Write here]

Risk Owner

[Write here]

Approvers

[Write here]

Expiry Date

[Write here]

Review Date

[Write here]

Closure Criteria

[Write here]

Day 11 Reflection Notes

Monday, March 23, 2026 11:20 AM

Am I comfortable challenging weak justifications for exceptions?
[Write here]

Do I think clearly in terms of compensating controls and residual risk?
[Write here]

How do I ensure exceptions stay temporary and accountable?
[Write here]

Day 12 – Security Assurance Gates

Monday, March 23, 2026 11:20 AM

Purpose of this exercise

The purpose of this exercise is to refresh how to define security checkpoints across the delivery lifecycle.

Security assurance gates help answer:

- what must be true before a project moves forward
- what evidence is needed at each stage
- whether the system is ready for go-live
- what risks remain open

1. Common Assurance Gates

Monday, March 23, 2026 11:20 AM

Gate 1 – Requirements / Initiation

Objective:

- identify business criticality
- identify data sensitivity
- identify baseline security requirements
- determine required security activities

Gate 2 – Design Review

Objective:

- review architecture
- identify trust boundaries
- assess access model
- identify key control gaps
- determine further assurance needs

Gate 3 – Build / Development Readiness

Objective:

- ensure secure coding expectations are known
- confirm SAST / SCA or other tooling requirements
- ensure secrets handling and logging are designed in
- confirm environment baseline expectations

Gate 4 – Test / Pre-Go-Live Security Review

Objective:

- confirm testing completed as required
- review critical and high findings
- validate remediation status
- assess logging and access controls
- prepare residual risk position

Gate 5 – Go-Live Security Sign-Off

Objective:

- determine if required controls are in place
- verify outstanding issues are understood
- confirm residual risks are documented and approved
- provide a recommendation to proceed, delay, or proceed with conditions

2. Security Architect’s Role in Assurance Gates

Monday, March 23, 2026 11:21 AM

I help define:

- what checks are required at each stage
- what evidence is sufficient
- what issues are blockers
- what can be accepted with conditions
- what requires formal risk acceptance

I also help ensure assurance is:

- proportionate to risk
- not introduced too late
- not reduced to checkbox exercise

3. Example Assurance Gate Checklist

Monday, March 23, 2026 11:21 AM

Project / System

[Write here]

Gate Stage

[Write here]

Required Security Activities

[Write here]

Required Evidence

[Write here]

Open Issues

[Write here]

Residual Risks

[Write here]

Recommendation

[Write here]

Approvals Required

[Write here]

Industry-Specific Notes

Monday, March 23, 2026 11:21 AM

FI

Assurance gates are often stronger around:

- transaction-sensitive workflows
- credit card/payment/account data
- privileged functions
- stronger testing evidence
- formal retest and closure expectations

GovTech

Assurance gates are often stronger around:

- citizen data protection
- public service trust
- officer/admin accountability
- privacy-sensitive logging and access controls
- confidence for public launch

Real Estate

Assurance gates are often stronger around:

- portal exposure
- document access controls
- SaaS/vendor governance
- admin and internal role separation
- practical evidence that controls are operating

Day 12 Workbook Exercise

Monday, March 23, 2026 11:22 AM

Draft one assurance gate using this structure:

Gate Name

[Write here]

Objective

[Write here]

Required Security Activities

[Write here]

Required Evidence

[Write here]

Blockers / Non-Negotiables

[Write here]

Risks That May Be Accepted With Conditions

[Write here]

Approver(s)

[Write here]

Output / Decision

[Write here]

Day 12 Reflection Notes

Monday, March 23, 2026 11:22 AM

Do I clearly distinguish between design review and go-live readiness?
[Write here]

What types of findings would I never allow to proceed without remediation?
[Write here]

How do I decide what can proceed with residual risk?
[Write here]

Day 13 – Audit Readiness and Traceability

Monday, March 23, 2026 11:22 AM

Purpose of this exercise

The purpose of this exercise is to refresh how to think in terms of:

- evidence
- traceability
- control verification
- defensible decision-making

A Security Architect should not only define controls.
They should also think:

- how will this be demonstrated?
- how will we prove this was reviewed?
- how do requirements connect to design, testing, and sign-off?

1. Traceability Thinking

Monday, March 23, 2026 11:22 AM

A strong security architecture process should be traceable from:

business context -> security requirement -> design control -> validation / testing -> evidence -> residual risk decision

This helps:

- auditors
- risk teams
- project governance
- security leadership
- future reviews

2. Basic Security Traceability Matrix

Monday, March 23, 2026 11:23 AM

Use this structure:

Requirement ID

[Write here]

Requirement Description

[Write here]

Related Risk / Threat

[Write here]

Design / Control Implemented

[Write here]

Verification Method

[Write here]

Evidence Available

[Write here]

Status

[Write here]

Owner

[Write here]

Residual Risk / Notes

[Write here]

3. Examples of Evidence

Monday, March 23, 2026 11:23 AM

Examples include:

- approved architecture review record
- data flow diagram
- access control model
- secure coding evidence
- SAST / SCA results
- VAPT report
- remediation record
- screenshots of configuration
- privileged access approval logs
- audit log samples
- risk acceptance record

4. Security Architect’s Role in Traceability

Monday, March 23, 2026 11:23 AM

My role is to ensure that:

- requirements are not vague
- design controls are not just assumed
- validation activities are planned
- evidence is identified early
- residual risks are recorded
- the decision trail is visible and defensible

Industry-Specific Notes

Monday, March 23, 2026 11:23 AM

FI

Traceability is especially important for:

- transaction and payment controls
- privileged access controls
- customer/account/card data protection
- evidence of testing and remediation
- strong audit trail of sensitive decisions

GovTech

Traceability is especially important for:

- personal data handling
- citizen-facing controls
- officer/admin access decisions
- privacy and accountability evidence
- public-sector audit defensibility

Real Estate

Traceability is especially important for:

- document access controls
- portal security
- vendor access governance
- evidence of reasonable and proportionate security measures

Day 13 Workbook Exercise

Monday, March 23, 2026 11:24 AM

Create a small traceability example for one system.

System / Project

[Write here]

Requirement ID

[Write here]

Requirement Description

[Write here]

Related Risk / Threat

[Write here]

Control Implemented

[Write here]

Verification Method

[Write here]

Evidence

[Write here]

Status

[Write here]

Owner

[Write here]

Notes / Residual Risk

[Write here]

Day 13 Reflection Notes

Monday, March 23, 2026 11:24 AM

Do I naturally think about evidence when I define controls?
[Write here]

Can I connect architecture review outputs to assurance evidence?
[Write here]

Where do I most often see traceability break down in real projects?
[Write here]

Day 14 – Week 2 Reflection and Consolidation

Monday, March 23, 2026 11:24 AM

Week 2 Summary

What I refreshed this week

[Write here]

What still feels rusty

[Write here]

What I can now explain more clearly

[Write here]

What document types I feel most confident creating

[Write here]

Which area I want to practice further

[Write here]